Improving Cybersecurity at FinSecure Ltd

Derek Charles Agyei

2415446
ACCA4024/17/09/25

Presentation Roadmap

- The report carefully curated by I, is to improve FSL's security.
- Area: External and internal threats.
- Method: Frameworks (GDPR, NIST CS F, CIA Triad, ISO 27001.) (Diagram below shows the exact policies that will be introduced.
- Result: Increased staff knowledge, realistic measures, and strict rules

Framework	Threat Catergory	Possible Scenarios	Policy Measures
ISO 27001	Insider Threats	Staff may have access to our clients financial data. if abused by bad actors, this could result in fraud or data leakage.	**Access Control Policy** enforcing least privilege
NIST CSF	External Threats	FSL has fell victim to **phishing** attempts and unauthorized access attempts on its network. NIST's "Detect" and "Respond" enable FSL to help, monitor and act quickly	**Multi-factior-authoriazation** enforcement, IDS/IPS logging
CIA TRIAD	Security Controls	FSL must store any and all financial transaction records that must remain accurate and available 24/7 for clients	**Data Protection Policy** ensuring encryption, patch management, backups
UK GDPR	Compliance	FSL processes and stores personal and financial data for UK clients.	**Article 32 GDPR**/keeping client financial data safe through strong protections. e.g encryption and access control. Including reporting any data breaches to the ICO within 72 hours.

Presentation Roadmap

- INTERNAL THREATS
- EXTERNAL THREATS
- SECURITY FRAMEWORKS & POLICIES
- MITIGATION MEASURES
- MONITORING & RESPONSE
- STAFF TRAINING & AWARENESS
- CONCLUSION

Internal Threats

HUMAN ERROR & NEGLIGENCE

PHISHING (E.G.,)EMAILS/LINKS)

RANSOMWARE (E.G., NHS WANNACRY)

STAFF AWARENESS GAPS

External Threats

- Brute force login attempts
- Credential stuffing (stolen/reused passwords)
- DDoS attacks disrupting services
- Attackers often combine techniques

Linking Insider & External Threats

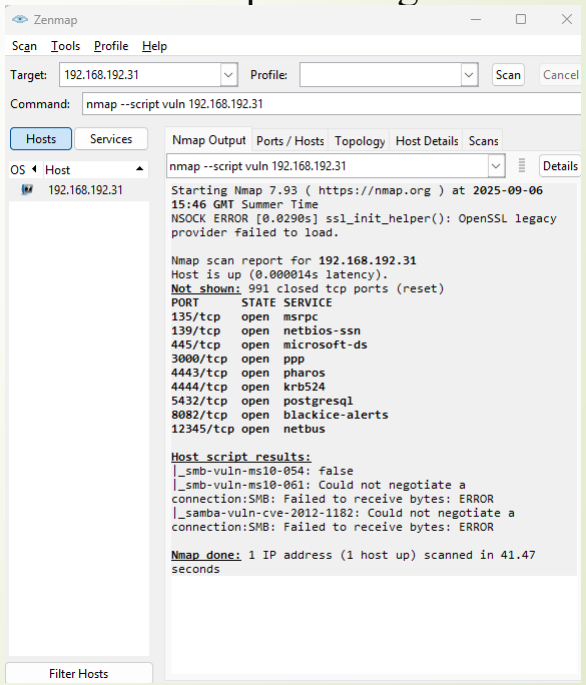
- External threats exploit staff mistakes
- Weak passwords + phishing = entry point
- DDoS as distraction for credential theft
- Technical controls alone are not enough

Security Policies

- Access control: least privilege
- Multi-Factor Authentication (MFA)
- Data encryption (at rest + in transit)
- GDPR breach reporting (ICO within 72 hrs)

Mitigation Measures

- Nmap scans: detect open ports/services
- Patch management: critical fixes to be reported (48 hrs)
- Anti-malware + EDR solutions
- Firewalls protecting network



This scan shows how attackers can see our open ports. By patching and controlling these, we mitigate further attacks.

Monitoring & Response

Training & Awareness

- Onboarding + 6-month refresher courses
- Phishing simulations to test staff
- Extra training for customer-facing staff
- Posters, newsletters, campaigns

Conclusion

Threats = internal + external, often linked

Policies address CIA Triad

Standards: ISO 27001, NIST CSF, GDPR compliance

Protects customer trust & regulatory status